

- Rerouting personnel to a safer location or authorizing telecommuting when the local area becomes unsafe.
- Authorizing telecommuting when an event causes disruptions to operations.
- Invoking disaster recovery procedures once management has identified a significant cyber attack.
- Activating emergency response procedures once a hurricane threatens the local region.

V.B Continuity and Recovery

Management should establish protocols for operations continuity and system recovery. The BCP may include:

- Addressing customer service requests during downtime.
- Tracking daily transactions.
- Reconciling general ledger accounts.
- Documenting operational tasks.
- Posting entries after system recovery.
- Maintaining backup records to provide customer account information (e.g., account numbers, customer names, addresses, account status, and account balances).
- Documenting steps for system hardware and software recovery and restart.

When appropriate, procedures should address manual steps for critical functions, such as back-office operations, loan operations, and customer support. Business continuity plans and procedures should be clear, concise, and easy to implement in an emergency,³² such as checklists and step-by-step procedures.

Displaced customers may not have access to their normal identification and personal records. The BCP should include alternate identity verification methods, and management should be alert for fraud or other suspicious activities. Procedures should address fraud identification³³ and suspicious activity reporting³⁴ according to protocols and legal requirements.³⁵

During the recovery phase, management should coordinate access and availability of power and telecommunications systems with various entities. Management should coordinate with the police and fire departments and local and state government agencies to facilitate timely, secure resilience strategies. Management may also coordinate with other federal agencies, such as the

³² Refer to NIST SP 800-34 Rev. 1, [Contingency Planning Guide for Federal Information Systems](#). NOTE: While this document pertains to federal information systems, the principles are relevant for non-federal information systems.

³³ Refer to the Financial Crimes Enforcement Network's (FinCEN) FIN-2006-A001, [Guidance to Financial Institutions Regarding Hurricane-Related Benefit Fraud](#).

³⁴ Refer to FinCEN's FIN-2013-G002, [Administrative Difficulties in Submitting Electronic Reports to FinCEN](#).

³⁵ Refer to 31 CFR 1020.220, [Customer Identification Programs for Banks, Savings Associations, Credit Unions, and Certain Non-Federally Regulated Banks](#).

Federal Emergency Management Agency, depending on the disaster severity. Refer to the *IT Handbook's* "Operations" booklet for additional information.

V.C Facilities and Infrastructure

The BCP should identify alternatives for core operations, facilities, infrastructure systems, suppliers, utilities, interdependent business partners, and key personnel. The backup site may mirror the operational functionality of the primary site. Management should consider site relocation for short-, medium-, and long-term scenarios. When selecting a facility, management should plan for scalability because an event may last for an extended period of time. In addition, management should consider the entity's proximity to police, fire, and medical facilities, and the expected response time frames should be factored into recovery strategies. Management should enlist the assistance of state and local agencies to expedite building permits and inspections for temporary facilities. Management should verify that recovery alternatives can accommodate the services and processing capabilities affecting critical operations, including:

- Core processing.
- Check processing and imaging.
- Commercial cash management.
- Payments.
- Mailing, faxing, and printing.
- Customer identification.

V.C.1 Data Center Recovery Alternatives

Data center recovery alternatives vary for infrastructure, configuration, operational state, and data migration. Management should document the reasons (e.g., cost and service level) for choosing an alternative and why it is appropriate based on the entity's risk profile and complexity. The level of intervention required to activate the alternate sites affects both the cost and duration to resume operations. Recovery alternatives may take several forms, such as fully redundant systems at alternate sites, cloud-based recovery solutions (either internally developed or outsourced), another data center, or a third-party service provider. Data center and alternate site development is complex, and management should consider constraints in the analysis and design process. The primary objectives are for data to be available and remotely accessible. Management should maintain appropriate controls, regardless of solution. Alternative recovery site examples may include:

- **Cold site:** A backup facility that has the necessary electrical and physical components of a computer facility, but does not have the computer equipment in place. The facility is ready to receive computer equipment when personnel move from their main computing location to the backup facility. This facility is usually not considered as the primary recovery option within the financial services industry because of the significant time necessary to install and activate the infrastructure. Comprehensive testing cannot occur until the infrastructure is established.
- **Warm site:** An environmentally conditioned work space that is partially equipped with information systems and telecommunications equipment to support relocated operations in

the event of a significant disruption. The systems are not loaded with the software or data required to resume operations and typically require manual intervention for failover and system reboots to resume critical processes. Therefore, end users may experience some disruption.

- **Hot site:** A fully operational off-site data center equipped with hardware and software used in the event of an information system disruption. Hot site development is complex, and management should consider constraints in the analysis and design process.
- **Mirrored data recovery sites:** Two or more separate, active sites that back up one another with each site independently supporting critical business functions. These sites provide almost immediate resumption capacity and are seamless for end users. Physical distance and its related latency present limitations for data centers that use real-time, data mirroring backup technologies. Similar to a hot site, these sites contain all of the equipment and connectivity capabilities; however, they also have a duplicate copy of the data. This method of high availability is commonly referred to as “Active-Active.”
- **Mobile site:** A site that possesses capabilities between what a warm and a cold site offer and has portable structures equipped with computing equipment available to customers or personnel. Completely activating a mobile site depends on how quickly it can be delivered and backups restored.
- **Colocation facility:** A facility that provides space, power, infrastructure, environmental controls, and telecommunications capabilities for multiple non-related tenants. If management relies on a colocation facility to deliver resources, there is a risk that the capacity at the colocation service provider may not be able to support the entity’s operations during a regional or large-scale event.
- **Reciprocal agreement:** An agreement that allows two entities to back up each other. While these agreements may be cost-effective, they are viable only if there is adequate excess capacity at the reciprocal financial institution and both operate on the same version and configuration of core software. Consideration should be given to security and privacy, as sensitive customer information could be exposed to the staff at the reciprocal financial institution. While these arrangements may be acceptable as a short-term solution, management should not rely on them as a long-term recovery solution.
- **Disaster recovery as a service (DRaaS):** A cloud-computing solution for replicating and hosting infrastructure, applications, and data that provides failover and recovery services.

V.C.2 Branch Relocation

An adverse event may lead management to temporarily limit or cease branch operations or temporarily transfer a branch’s operations to alternate locations. An important BCP component is establishing a physical location where personnel and customers can go to conduct business. For financial institutions, approval by the appropriate regulator may be required to close, relocate, or establish additional branch facilities.³⁶

³⁶ Refer to 12 U.S.C. 1831r-1, “[Notice of Branch Closure](#)”; 64 Fed. Reg. 34844, “[Policy Statement of the Office of the Comptroller of the Currency, Board of Governors of the Federal Reserve System, Federal Deposit Insurance Corporation, and Office of Thrift Supervision Concerning Branch Closing](#)”; 12 CFR 303, Subpart C, “[Establishment and Relocation of Domestic Branches and Offices](#)” (FDIC); 12 CFR 208.6, “[Establishment and Maintenance of Branches](#)” (FRB); 12 CFR 5.30, “[Establishment, Acquisition, and Relocation of a Branch of a National Bank](#)”

V.D Payment Systems

The BCP should address alternate arrangements if payment systems fail (e.g., automated teller machines (ATM), funds transfers, electronic banking, remote deposit capture, or mobile capabilities). Alternate solutions may include manual procedures for calling in or faxing wire or automated clearing house requests to correspondent financial institutions. In addition, web-based systems or third-party software may be used to perform transactions. Management should verify that redundant electronic payment systems and equipment (e.g., tokens and routers) are included at recovery sites for activation and that documentation is maintained for timely posting of entries when systems are recovered.

The BCP should also address increased cash demands and moving funds through electronic systems, including internet and mobile banking. Management may consider developing procedures for pre-established withdrawal limits based on the financial institution's relationships with customers. In addition, management should prepare for a potential increase in branch traffic when ATMs are unavailable. Pre-established agreements with various cash delivery services within and outside of the local area should also be considered so that ATMs can meet customer demand when service returns.

V.E Liquidity Considerations

The BCP should detail processes to address potential cash and liquidity needs during adverse events. During a disaster, power and communications systems may fail (e.g., inoperable ATMs or debit and credit card systems), requiring cash to fulfill customer and business needs. Arrangements to help meet liquidity needs may include:

- Emergency borrowing access.
- Alternative cash delivery.
- Procedures to secure, deliver, and distribute cash.
- Temporary purchase authority guidelines.
- Expense reimbursement options for personnel.
- Higher-limit credit cards or separate checking accounts, with designated individuals who can sign checks in emergency situations.

V.F Other Components

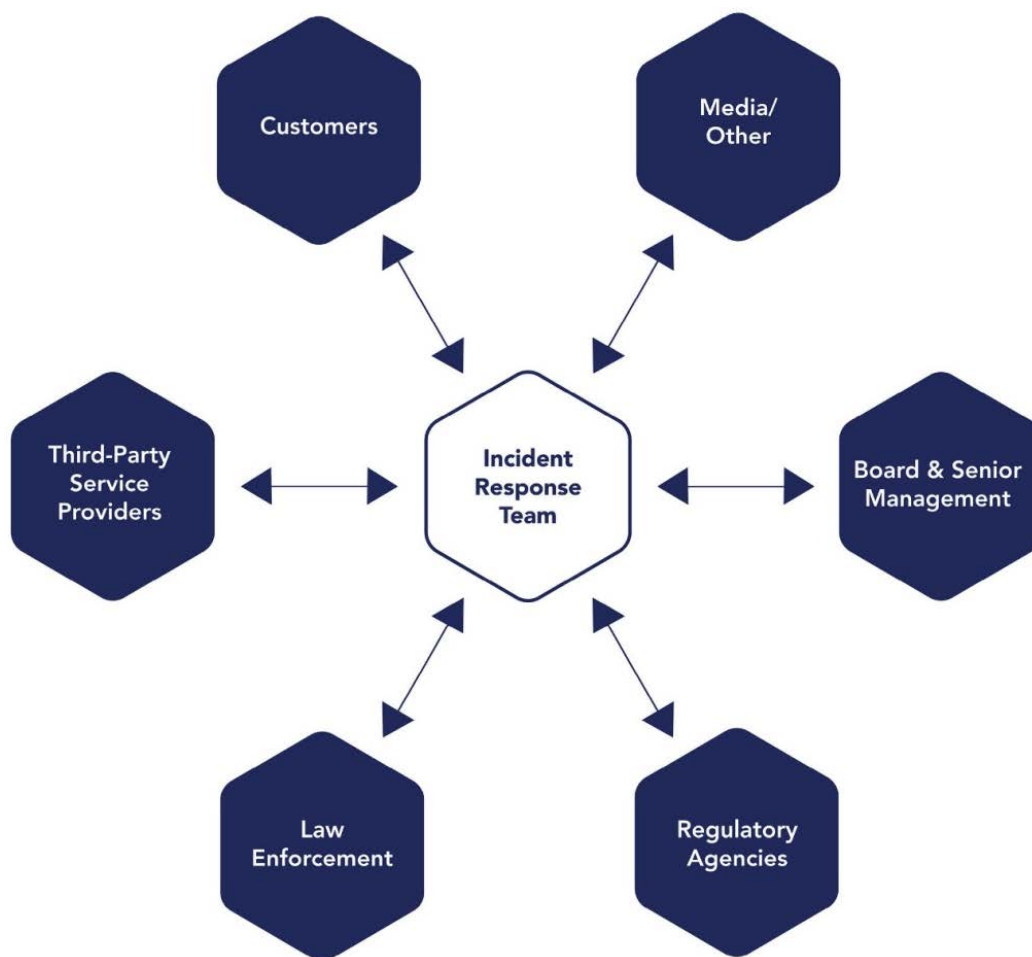
The BCP focuses on sustaining business processes during and after an event. The BCP may incorporate other plans and procedures to minimize a disruption's impact. Components may include incident response, disaster recovery, and crisis or emergency management.

(OCC); and 12 CFR 5.31, "[Establishment, Acquisition, and Relocation of a Branch and Establishment of an Agency Office of a Federal Savings Association](#)" (OCC).

V.F.1 Incident Response

Incident response helps management minimize the disruption of services or loss of information from an adverse event. Incident response priorities include preservation of life, preservation of property, incident stabilization, and communicating with stakeholders (e.g., impacted personnel, third-party service providers, customers, regulators, law enforcement). As shown in figure 4, the incident response team should coordinate communication with the noted stakeholders. Management should align incident response procedures with other related processes (e.g., cybersecurity, network operations, and physical security), outsourced services (e.g., contracted incident response obligations), and verify that the procedures are considered during planning and BCP development.

Figure 4: Incident Response Team (Adapted From NIST SP 800-61, Rev. 2)



Management should designate a spokesperson(s) to communicate with the news media. Management should consider various, pre-planned response scenarios approved by the board and senior management. Communication with the news media and via social media may be important for disseminating accurate information. Social media monitoring during an event can help management resolve conflicting messages and proactively respond to issues and concerns.

Management should train personnel to adhere to the plan when approached by the news media or communicating via social media.

Furthermore, management should leverage routine processes (e.g., vulnerability management and network monitoring) to anticipate potential incidents, including cyber incidents, and coordinate incident response planning with any third-party service provider plans. Furthermore, management should consider prearranging third-party forensic and incident response services. Management should periodically update and test the entity's incident response program to verify that it functions as intended, given rapidly changing threats. Refer to the *IT Handbook's* "Information Security" booklet for additional information.

V.F.2 Disaster Recovery

Disaster recovery is the restoring of IT infrastructure, data, and systems. Management should identify key business processes and activities to be maintained while IT systems and applications are unavailable and prioritize the order in which these systems are restored, which should be reflected in the BIA. In addition, management should develop a coordinated strategy for the recovery of data centers, networks, servers, storage, service monitoring, user support, and related software.

Recovery plans should address a broad range of adverse events (e.g., natural disasters, infrastructure failures, technology failures, unavailability of staff, or cyber attacks). Disaster recovery should address guidelines for returning operations back to a normalized state with minimum disruption.

Disaster recovery should also address the following:

- Security controls and protocols, including physical and logical, for implementation and operation of recovery systems.
- Procedures for restoring backlogged activity or lost transactions to identify how transaction records will be brought current within expected recovery time frames.
- Instructions to access critical information repositories and other resources when the primary facility is unavailable.

When developing disaster recovery plans, management should exercise caution when identifying critical and non-critical systems. For example, telephone banking, internet banking, or ATMs may not seem critical when systems are operating normally; however, these systems play a critical role in delivering services to customers during a disruption. Similarly, an email system may not appear critical but may be the primary system available for communication during an adverse event.

V.F.3 Crisis or Emergency Management

Crisis or emergency management³⁷ is the process that allows the recognition of a crisis, activation of a BCP, and management of emergencies. Crisis or emergency management includes the ability to recover from a major event through predefined leadership and communication. Not every event warrants a crisis or emergency management response. Management should consider the impact of a crisis or emergency on the entity's reputation and personnel. For example, management may invoke crisis or emergency response procedures during a natural disaster, cyber attack, or other high-profile event.

The crisis or emergency management portion of the BCP should address coordination with regulatory agencies, local and state officials, law enforcement, and first responders. Scenarios should detail disruptions, and not be confined to a single event, facility, or geographic area. Also, crisis or emergency management plans should address simultaneous disruptions of telecommunications and electronic messaging, including between the entity and third-party service providers.

Management should designate key personnel from applicable departments to act during a crisis or emergency situation, commensurate with the entity's size and complexity. Designated personnel should be authorized to make decisions in a timely manner. Key personnel may include:

- Senior management for leadership.
- Facilities management for safety and physical security.
- Human resources for personnel issues, travel, and relocation.
- Media relations for managing communications.
- Finance and accounting for funds disbursement and financial decisions, including unanticipated expenses.
- Legal and compliance for legal and regulatory concerns.
- IT, including information security, and operations for specific tactical responses.

Communication protocols for a crisis or emergency event should include contact lists and other viable methods to reach personnel and other stakeholders who may be called upon during a crisis. The contact list should be distributed and accessible to key personnel and should be verified and updated regularly. Management should be able to communicate with personnel located in isolated areas or dispersed across multiple locations. Procedures should enable employees to report their status in a centralized manner and obtain current information. Crisis or emergency management communication protocols should include provisions to contact the entity when normal communication channels are inoperable.

Notification systems can be manual or automated. In less complex environments, manual communication techniques, such as call trees, are often used; however, information gathering can

³⁷ The financial services industry uses the terms "crisis management" and "emergency management" interchangeably.

be time consuming, and responses can be unreliable in a crisis. Maintaining contact information can become unwieldy for large entities; therefore, automated solutions may be used.

VI Training

Action Summary

Management should implement a business continuity training program for all stakeholders.

Examiners should review for the following:

- Objectives of business continuity training.
- Alignment of business continuity training with strategies.
- Extent of targeted business continuity training provided to stakeholders, such as personnel, business continuity program staff, and the board.
- Format of the business continuity training program.
- Process for reviewing and updating the business continuity training program.

Management should include training as part of an effective business continuity program to educate stakeholders on resilience, business continuity goals, corporate-wide objectives, policies, and individual personnel roles and responsibilities. The board or senior management delegates a committee or individual to oversee the training program; however, the board should be responsible for the training program's effectiveness. Refer to the *IT Handbook's* "Management" booklet for additional information.

The training program should align with the entity's strategy and use a comprehensive, risk-based, multi-year approach, including interrelated programs (e.g., disaster recovery and third-party risk management). The frequency of exercises should depend on the size and complexity of the entity and the elements of the training program, risks, and testing program iteration, with all elements covered in a timely manner. Management should take inventory of the current skill sets for business continuity and identify and address any gaps. When appropriate, management should establish goals and objectives for supporting the entity's business continuity program as part of the performance management process. Some elements of the training program may include:

- Exercises.
- Current risks.
- Future risks.
- Recent failures.
- New programs/technologies.
- Organizational changes.
- Previous (exercise) lessons learned.

Training generally involves a conceptual understanding of business continuity, including testing methods, test results, and critical business functions. The training program should include conditions for activating the BCP and what to do when key personnel are unavailable. Training should selectively and purposely seek to validate plans and assumptions by testing the interactions of people, processes, and technology risks and vulnerabilities in a consequence-free exercise environment.

Training should be tailored to the target audience, addressing the needs of specific groups. Training participants should include the board, senior management, business process owners, and frontline personnel. For example, training for personnel who manage the business continuity program should be different than training for personnel not directly involved in recovery operations. Training should include significant business continuity concepts, interdependencies, disruption impacts, and operational resilience. When applicable, contractors involved with the business continuity program should also receive appropriate training.

The board should understand the business continuity program, testing initiatives, and key business continuity-related reports. Board training should occur regularly, or more frequently, based on significant changes to business processes, risks, BIA results, or lessons learned from incidents that have impacted the entity. Training methods may involve instructional classes, computer-based training, hands-on experience, lessons learned, and collaborating with other organizations. Role-based training includes cross-training personnel to compensate for significant absenteeism or operational disruptions, which may occur during an event. Training should reflect changes to the business continuity program as they occur.

VII Exercises and Tests

Action Summary

The board and senior management should provide for appropriate exercises and tests to verify that business continuity procedures support business continuity objectives. Exercises and tests should be used to validate one or more aspects of the entity's BCP.

Examiners should review for the following in exercise and testing plans:

- Provisions for exercises and tests occurring at appropriate intervals and when significant changes affect the entity's operating environment.
- Comprehensive program objectives and plans of exercises and tests to validate the ability to restore critical business functions in a timely manner.
- An exercise and test process that provides assurance for the continuity and resilience of critical business functions, without compromising production environments.
- Authorities and control over exercises and tests.
- Exercise and test policies, expectations, and strategies that demonstrate the entity's ability to utilize alternate facilities.
- Exercise and test objectives for resilience, system monitoring, and the recovery of business processes and critical system components.
- Exercise and test scenarios, including exercise and test assumptions, objectives, expectations, and assessment metrics.
- Types of exercises (e.g., full scale, limited scale, or tabletop) and tests.
- Exercises and tests related to interaction with third parties, industry-wide testing, and core and significant firms.
- Documentation of issues identified through exercises and tests, and action plans and target dates for resolution.
- Board expectations for overall business continuity capabilities, including guidelines to achieve defined business continuity objectives.

Exercises and tests³⁸ help ensure that business continuity procedures support business continuity objectives. An exercise is a task or activity involving people and processes that is designed to validate one or more aspects of the BCP or related procedures. There are many different types of exercises, depending on the intended goals and objectives. Exercises may include scenario-driven simulations of BCP elements. For example, exercises may include performing duties in a simulated environment (i.e., functional) or be discussion based (i.e., tabletop).

A test is a type of exercise intended to verify the quality, performance, or reliability of system resilience in an operational environment. Tests are evaluation tools that use quantifiable metrics to validate the operability of an IT system or system component in an operational environment

³⁸ For purposes of this booklet, the term "exercise" represents both exercises and tests, unless the term "test" is specifically mentioned.